NAIROBI, KENYA

Alvin Mwangi

I got into security kind of sideways — I was fixing a relative's laptop, got curious about why the home router's admin page had no password, and fell down a hole I haven't climbed out of since.

These days that curiosity has a bit more structure to it. I did the GoMyCode bootcamp and sat Security+, and most evenings I'm on HackTheBox working through boxes until something either breaks or finally opens up. I'm still early in this — I'd rather be upfront about that than oversell it — but I'm consistent, and I write down what I learn so I stop making the same mistake twice.

Looking for a junior pentest / SOC analyst role or something adjacent. Open to remote.

What I've actually worked through

Write-ups where I kept good enough notes to reconstruct the whole path.

Catching a hash with Responder, then arguing with John about it

HTB — AD-style lab

Turned on Responder to poison LLMNR/NBT-NS/mDNS on the segment and waited. Didn't take long — an NTLMv2-SSP hash for a privileged account showed up in the output. The part that actually took time was cracking it: I pointed John the Ripper at it with no format flag and it kept guessing wrong things (tripcode, descrypt, mysql — none of it right), and the session kept aborting.

Turns out that's normal for NTLMv2 hashes — the auto-detect genuinely struggles with them. Once I forced it with `--format=netntlmv2` against rockyou, it cracked in well under a minute.

> Lesson that stuck: don't trust John's auto-detect on anything NTLM-shaped. Just set the format.

Mapping a web target before touching it

HTB — web box

Ran Gobuster against the target with the DirBuster medium list, filtered 404s, restricted to html/php. Found the usual scaffolding — an assets folder, css/js dirs — nothing dramatic, but

it's the step I used to skip when I was newer and regretted skipping.

From an open WinRM port to a flag on the desktop

HTB — Windows host

Nmap turned up port 5985 open, which meant WinRM was worth trying. With the password I'd already cracked, `evil-winrm` dropped me into a shell as the user. From there it was just normal filesystem poking — `cd Desktop`, `ls`, and the objective was sitting right there.

> Not a flashy box. But it's the one that made the full chain — recon, credential capture, cracking, access — click for me as one process instead of separate skills.

A leftover config file, a shaky SQL shell, and an Administrator who forgot to clear his history

HTB — Windows Server, MSSQL

Nmap showed the usual AD ports plus `1433` — MSSQL. On an SMB share I found `prod.dtsConfig`, a deployment config file, and `cat`-ing it turned up a connection string with a cleartext password for a `sql_svc` account sitting right in the XML. Lucky, in the way these boxes are usually lucky.

First login attempt with Impacket's `mssqlclient.py` just failed — `Login failed for user 'ARCHETYPE\Guest'`. Took me a minute to realize what was happening: without `-windows-auth`, impacket treats it as a SQL login and it quietly falls back to Guest instead of actually trying the domain account. Added the flag, reconnected, and got a proper SQL shell as `ARCHETYPE\sql_svc`.

From SQL to OS command execution via `xp_cmdshell` should've been simple and wasn't — I kept writing Windows paths with forward slashes out of habit and PowerShell's parameter parsing didn't like it. Impacket's target string also wants `domain/user:password@target`, not the backslash form I kept typing from muscle memory. Small thing, cost me more time than it should have.

Once that was sorted: generated a meterpreter payload with `msfvenom`, served it with a quick `python3 -m http.server`, and used `xp_cmdshell` to have the target pull it down and run it. Caught the callback on a `multi/handler` — `getuid` confirmed I was `ARCHETYPE\sql_svc`, a service account, not an admin.

Ran WinPEAS from there to look for a way up, and the thing that actually got me there was almost embarrassingly simple: `sql_svc`'s PowerShell history file (`ConsoleHost_history.txt`) still had an old `Invoke-Command` line in it with the

Administrator's password in plain sight. Fed that straight into `evil-winrm` and landed a full Administrator shell.

> The actual technical skills here weren't the hard part — reading my own errors carefully was. Every delay in this one was me misreading a message, not missing a vulnerability.

Other boxes, less detailed notes

I didn't screenshot every step on these, but here's roughly how each one went.

Crocodile	anonymous FTP led into a web foothold
Fawn	anonymous FTP login, grabbed the file, done
Redeemer	Redis with no auth set — walked right in
Sequel	MySQL still on default creds
Appointment	basic SQLi on a login form, auth bypass
Dancing	SMB share open to anyone, no login needed
Meow	Telnet, default creds, root straight away — my very first box

Certifications

Cyber Security Bootcamp — CompTIA Security+ (701)	GoMyCode, Apr 2025
Web App Pen Test Basics	CSEM, Mar 2026
Operating Systems Basics	CSEM, Mar 2026
API Security Learning	CSEM, Mar 2026
Networking Basics & Fundamentals	CSEM, Mar 2026
Network Monitoring & Threat Detection	CSEM, Apr 2026
Encryption in Transit (TLS, ACM, CloudFront)	CSEM, Apr 2026

Alvin Mwangi. Still learning, still breaking things on purpose.